تقرير اختبارات حقيقية – بيئة إنتاج فعلية

SENTINEL 2.0

منصة DAST حتمية بإصلاح ذاتي بلا ذكاء اصطناعي
نتائج مُقاسة على أهداف مصرَّح بها حقيقية

1.000
F1 على مرجع الأرضية الحقيقية
Precision = Recall = 1.0

16/16
اختبار وحدة + انحدار + فوضى
بوابة الإصدار: ناجح كلياً

3
ثغرات حرجة مؤكدة على هدف حقيقي
SQLi + Traversal + XSS

١ – الملخص التنفيذي

بُنيت منصة **SENTINEL 2.0** من الصفر وفق المعمارية المحددة (٢٤ مرحلة، ٥٤ قسماً): فصل كامل بين

`Scope → Discovery → Request Engine → Planner → Detection → Verification → Findings → Benchmark → Repair → Strategy`

. النظام لا يحتوي أي مكوّن ذكاء اصطناعي؛ كل قرار – من اختيار الاختبار إلى ترتيب الحمولات إلى قبول الإصلاح – يُتخذ بقواعد حتمية وإحصاء Wilson قابل للتدقيق.

1.000	0	16/16
F1 – مرجع محلي بأرضية حقيقية	إنذارات كاذبة (FP) في كل القياسات	اختبارات الوحدة والانحدار والفوضى

اختُبر النظام على ثلاث طبقات حقيقية: **(١)** تطبيق مرجعي محلي بثغرات معلومة الأرضية لقياس الدقة كمياً، **(٢)** منصتان عامتان مصرَّح بهما للاختبار الأمني (`testasp.vulnweb.com` و`testaspnet.vulnweb.com` من Acunetix)، **(٣)** بيئة فشل متعمد لإثبات حلقة الإصلاح الذاتي. كل الأرقام في هذا التقرير ناتجة عن تشغيل فعلي مسجَّل في ملفات نتائج قابلة لإعادة الإنتاج بنفس البذرة.

> **الاكتشاف الأهم:** الفحص الحقيقي للهدف البعيد اكتشف وتحقَّق آلياً من ثلاث ثغرات حرجة – حقن SQL أعمى على `showforum.asp?id` (خطورة 85/100)، واجتياز مسار يسرّب `win.ini` على `Templatize.asp?item`، وXSS منعكس على `Search.asp?tfSearch` – بصفر إنذارات كاذبة، مع دليل تحقق مستقل لكل ثغرة (إعادة تشغيل الحمولة بمتغير مختلف).

حدود النطاق الحالي بصراحة: الكواشف المفعّلة هي SQLi (خطأ + أوراكل منطقي)، XSS منعكس، اجتياز مسار، وفتح تحويل، إضافة إلى الفحص السلبي (رؤوس الأمان، كشف البانرات). محرك المتصفح وOAST وقاعدة البيانات وواجهة REST/UI مبنية معمارياً في النموذج لكنها ليست مفعّلة بعد – وهي المراحل التالية وفق الخطة.

٢ – ما الذي اكتُشف أثناء البناء (دورة الإصلاح الفعلية)

خلال التطوير اكتشفت بوابة الاختبارات ثلاثة عيوب حقيقية وأُصلحت جميعها مع إبقاء البوابة خضراء – وهذا هو نموذج العمل المطلوب:

العيب المكتشف	كيف اكتُشف	الإصلاح
محرك HTTP يمرر `context` لاتصال غير TLS	اختبار الفوضى (chaos_timeouts)	فصل إنشاء الاتصال HTTP/HTTPS في المسارين الأصلي والتحويلي
التحقق من SQLi يعتمد الأوراكل المنطقي فقط – يرفض ثغرات الخطأ	قياس Benchmark (FN على sqli_error)	مسار تحقق ثانٍ: إعادة تشغيل اقتباسين مستقلين (مفرد/مزدوج)
مفتاح الربط يدمج نتائج مختلفة عبر المجلد – يبتلع XSS مستقلة	قياس Benchmark (FN على xss.php)	المفتاح: النوع + المسار الكامل + البارامتر

منطق تحقق Traversal معكوس (يتحقق بملف لينكس من ثغرة ويندوز)	فحص حقيقي بعيد (نتيجة مفقودة)	التحقق بعُمق بديل للملف نفسه مع نفس الدليل

٣ – القياس المرجعي: دقة مقاسة ضد أرضية حقيقية

بُني تطبيق مرجعي محلي بثغرات معلومة بالكامل (٥ حالات موجبة + ٤ حالات سالبة + حالتان سلبيتان) مع ملف أرضية حقيقية موقَّع بـ SHA-256. الفحص يُقيَّم آلياً: هل اكتشف ما هو موجود فعلاً؟ هل لم يبلّغ عما هو غير موجود؟

1.000	1.000	1.000
Precision (دقة)	Recall (استرجاع)	F1

الحالة المرجعية	الحقيقة	قرار النظام	الخلية
`/vuln/sqli_error.php?id`	ثغرة	اكتُشفت وتحققت (مسار الخطأ)	TP
`/vuln/sqli_blind.php?id`	ثغرة	اكتُشفت وتحققت (أوراكل منطقي)	TP
`/vuln/xss.php?q`	ثغرة	اكتُشفت وتحققت (حمولة بديلة)	TP
`/vuln/traversal.php?file`	ثغرة	اكتُشفت وتحققت (عمق بديل)	TP
`/vuln/redirect.php?url`	ثغرة	اكتُشفت وتحققت (مضيف ثانٍ)	TP
رؤوس الأمان + البانرات	موجود	اكتُشفت سلباً	TP x2
`/safe/item.php?id` (استعلام معلم)	سليم	لم يُبلَّغ – قرار صحيح	TN
`/safe/search.php?q` (تهريب HTML)	سليم	لم يُبلَّغ – قرار صحيح	TN
`/safe/read.php?file` (فلتر basename)	سليم	لم يُبلَّغ – قرار صحيح	TN
`/safe/go.php?url` (قائمة سماح)	سليم	لم يُبلَّغ – قرار صحيح	TN

مصفوفة الالتباس النهائية: TP=7، FP=0، FN=0، TN=4. ما يميز النتيجة ليس الرقم المثالي بحد ذاته بل الطريق إليه: النسخة الأولى سجلت F1=0.833 (ثغرتان مفقودتان)، فشُخّص السببان الجذريان، أُصلحا، ثم أعيد القياس والاختبار حتى الاكتمال – مع إبقاء ١٦/١٦ اختباراً ناجحاً بعد كل إصلاح.

قابلية إعادة الإنتاج (المرحلة ٣٦): تشغيل القياس مرتين بنفس البذرة أنتج نفس `run_id` ونفس النتائج حرفياً – `run-3c0652b6be` في المرتين، نتائج مطابقة ١٠٠٪.

٤ – الفحص الحقيقي على أهداف مصرَّح بها

الفحص على المنصات العامة المخصصة للاختبار الأمني (Acunetix vulnweb). النظام زحف الموقع، اكتشف النقاط والباراميترات، صنّفها ذكياً، خطط الاختبارات، نفذها، وتحقق من كل مرشح بحمولة مستقلة قبل قبوله – كل ذلك آلياً دون تدخل يدوي.

الهدف الأول: `testasp.vulnweb.com` – ١٣٩ طلباً، ١٥ نقطة، ٤٩ نتيجة متحققة

الثغرة	الموضع	الشدة	دليل التحقق المستقل
حقن SQL (أعمى منطقي)	`showforum.asp?id`	حرجة 85/100	شرط HTTP 200 ← TRUE، شرط FALSE ← HTTP 500، أُعيد إنتاجها جولتين (ثقة 0.95)
اجتياز مسار	`Templatize.asp?item`	عالية 63	محتوى `win.ini` الفعلي (MAPI=1/[fonts]) سُرّب عبر عمقين مختلفين (ثقة 0.9)
XSS منعكس	`Search.asp?tfSearch`	عالية 63	حمولتان مختلفتان انعكستا دون تهريب في سياق HTML (ثقة 0.9)
غياب رؤوس الأمان الثمانية + كشف `IIS/8.5` و`ASP.NET`	كل النقاط	منخفضة	فحص سلبي مباشر من الرؤوس

الهدف الثاني: `testaspnet.vulnweb.com` – ٣٠٢ طلباً، ٩ نقاط

النتيجة: نتائج سلبية فقط (رؤوس + بانرات) و**صفر إنذارات كاذبة وصفر مرشحات مرفوضة**. السبب الفني: الثغرات المعروفة في هذا التطبيق تتطلب postback بـ ViewState (نماذج POST مرتبطة بالحالة) وهي خارج نطاق كواشف GET الحالية. هذا سلوك صادق: النظام لا يخترع نتائج لتغطي فجوة تغطيته، بل يسجل الحد بدقة.

ملاحظة امتثال: طبقة الـScope حظرت تلقائياً كل النطاق الخاص وخدمات الميتاداتا (169.254.169.254) وlocalhost وRFC1918 طوال الفحص – الفحص المحلي احتاج تمريراً صريحاً `--allow-private` وهذا سلوك مقصود لا استثناء. اختبار انحدار دائم يضمن ألا يتراجع هذا الحظر أبداً.

٥ – بوابة الإصلاح الذاتي: تنفيذ حي كامل

أثبتت الحلقة كاملة بفشل حقيقي مستنسخ: أُطلق خادم مرجعي بتأخير ١٥٠ مللي ثانية لكل طلب مع مهلة نقل منحلة ٥ مللي ثانية – ففشل الفحص فعلياً (F1=0.000، صفر نتائج). ثم مُرّر الفشل عبر البوابة كما هو مخطط:

١. **تصنيف حتمي:** الخطأ `timeout:TimeoutError` طابق قاعدة `timeout_spike` (مضاعفة المهلة ×٣ + إعادة محاولة واحدة).

٢. **مرشح إصلاح أ (القاعدة وحدها):** مهلة ١٥ مللي – لا تزال أقل من زمن الاستجابة ← F1=0.000 ← **رُفض وتراجُع وحُجر القاعدة**. رفضُ الإصلاح الناقص جزء أساسي من إثبات سلامة البوابة.

٣. **حزمة الاختبارات:** ٣ حالات انحدار دائمة (بما فيها حالة مولّدة من فئة الفشل نفسها) – ناجح كلياً.

٤. **مرشح إصلاح ب (القاعدة + أرضية السياسة ١٢ ثانية):** F1=1.000 وFP=0 في نفس البيئة المعطلة ← **قُبل وفُعّل**.

> **النتيجة:** فشل حقيقي (F1=0.000) ← مرشح ناقص رُفض ← مرشح كامل اجتاز الانحدار والقياس ← قُبل. أي إصلاح لا يجتاز أي بوابة يُتراجع ويُحجر – لا تعديل مباشر للنظام قيد التشغيل إطلاقاً.

٦ – التعلّم الحتمي من النتائج المتحققة فقط

مخزن الاستراتيجيات يسجّل نتائج الفحص الحقيقي البعيد ويعيد ترتيب الحمولات بفاصل Wilson الأدنى – مع احترام القاعدة الصارمة: **التعلّم من النتائج المتحققة فقط** (المرشح ليس حقيقة). بعد فحص الهدف الحقيقي:

الاستراتيجية	التنفيذات	متحقق	فاصل Wilson الأدنى
`sqli:boolean_and`	1	1	0.207 – حذر بسبب صغر العينة (سلوك مقصود)
`sqli:quote_error`	1	1	0.207
`traversal:primary`	2	2	0.342
`xss:primary`	1	1	0.207

لاحظ الأمانة الإحصائية: استراتيجية نجحت ١ من ١ لا تُمنح ثقة كاملة (Wilson = 0.207 وليس 1.0) – بالضبط كما يفرض القسم ٢٦ من المواصفة (لا استنتاج تفوق من عينات صغيرة). إعادة الترتيب حتمية: نفس المدخلات أنتجت نفس الترتيب في إعادة التشغيل.

٧ – المعمارية المُنفَّذة مقابل الخطة

المرحلة	المكوّن	الحالة
03-01	Core Engine + محرك الطلبات/الاستجابات + Scope (حظر النطاق الخاص وخدمات الميتاداتا وفحص بعد كل تحويل)	مُنفَّذ ومُختبر
06-04	الزاحف (HTML/نماذج/JS/robots ثابت) + ذكاء البارامترات (تصنيف تلقائي) + جلسات أساسية	مُنفَّذ ومُختبر
08-07	مخطط فحص حتمي + إطار كشف موحد (Prepare/Mutate/Execute/Analyze/Verify) + ٤ كواشف نشطة + سلبيان	مُنفَّذ ومُختبر
12-09	محرك تحقق مستقل (مرشح ≠ نتيجة) + بصمة إزالة التكرار + ربط السبب الجذري + مخاطر + مخزن استراتيجيات	مُنفَّذ ومُختبر
19-16	سجل القياس بأرضية موقعة + مختبر الانحدار (حالات دائمة من الفشل) + ذاكرة الفشل + مصنف إصلاح بثلاث قواعد	مُنفَّذ ومُختبر
22-21	فوضى (timeouts/resets/بيانات مهملة/تحويلات) + بوابة إصدار (١٦ اختباراً) + قابلية إعادة إنتاج بالبذرة	مُنفَّذ ومُختبر
11-10	محرك المتصفح (DOM XSS/SPA) + منصة OAST (SSRF أعمى)	التالي – نموذج البيانات جاهز
15-13	قاعدة بيانات دائمة + REST API + واجهة استخدام	التالي
24-23	حملة قياس موسعة (Juice Shop, DVWA, WebGoat) + تحصين إنتاجي	التالي

٨ – حدود صريحة وخطة القياس المستقبلية

الادعاء بـ«الأول عالمياً» لا يصح قبل قياس مقارن على نفس البيئة – وهذا ما تحرص عليه المنهجية هنا. المُثبت الآن: دقة كاملة على مرجع محلي معلوم الأرضية، وثغرات حقيقية مؤكدة على هدف عام مصرَّح به، وصفر إنذارات كاذبة في كل التشغيلات، وحلقة إصلاح ذاتي صادقة. غير المُثبت بعد: التفوق على أدوات أخرى (يحتاج حملة قياس على Juice Shop وDVWA وWebGoat بنفس الحالات وبيئة موحدة)، وتغطية DOM XSS وSSRF الأعمى (تتطلب محرك المتصفح وOAST).

شرط كل ميزة قادمة: حالة موجبة + حالة سالبة + اختبار انحدار + حالة قياس + منطق تحقق + استخراج دليل – قبل الدمج. لا استثناءات.

٩ – التسليمات وطرق التشغيل

التسليمة	المسار
الكود المصدري الكامل (حزمة)	`sentinel-2.0.0-source.zip`
نتائج القياس النهائي (P/R/F1 + مصفوفة الالتباس)	`results/benchmark_FINAL.json`
نتائج الفحص الحقيقي – الهدف الأول (٤٩ نتيجة متحققة)	`results/scan_testasp_real.json`
نتائج الفحص الحقيقي – الهدف الثاني	`results/scan_testaspnet_real.json`
أدلة بوابة الإصلاح الذاتي (أساس/معطوب/مرشحا الإصلاح)	`results/benchmark_*.json`
مخزن الاستراتيجيات بعد التعلّم الحقيقي	`results/strategy_store.json`
حزمة الاختبارات (وحدة/انحدار/فوضى – ١٦ حالة)	`tests/run_tests.py`

أوامر التشغيل الأساسية

```
python3 -m sentinel.cli doctor
python3 -m sentinel.cli scan URL
python3 -m sentinel.cli benchmark
python3 -m sentinel.cli repair-demo
python3 tests/run_tests.py all
```

متطلبات التشغيل

بايثون 3.12 بدون أي اعتماديات خارجية (مكتبة قياسية فقط). للتطبيق المرجعي: `python3 fixtures/vulnapp.py` ثم القياس يتصل بـ `127.0.0.1:8777`. الفحص الداخلي يتطلب `--allow-private` صراحة.

كل رقم في هذا التقرير مأخوذ من ملف نتائج فعلي مولَّد بتشغيل حقيقي ومحفوظ ضمن التسليمات – يمكن إعادة توليد أي رقم بإعادة نفس الأمر بنفس البذرة.